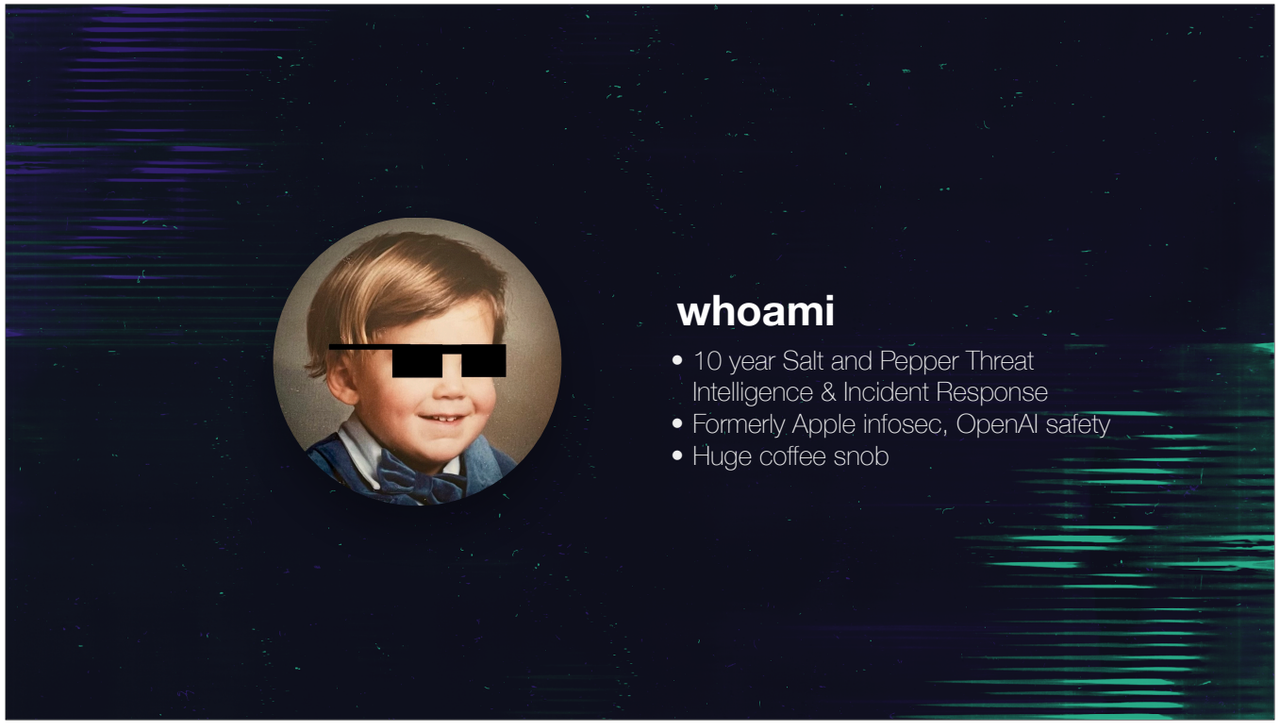
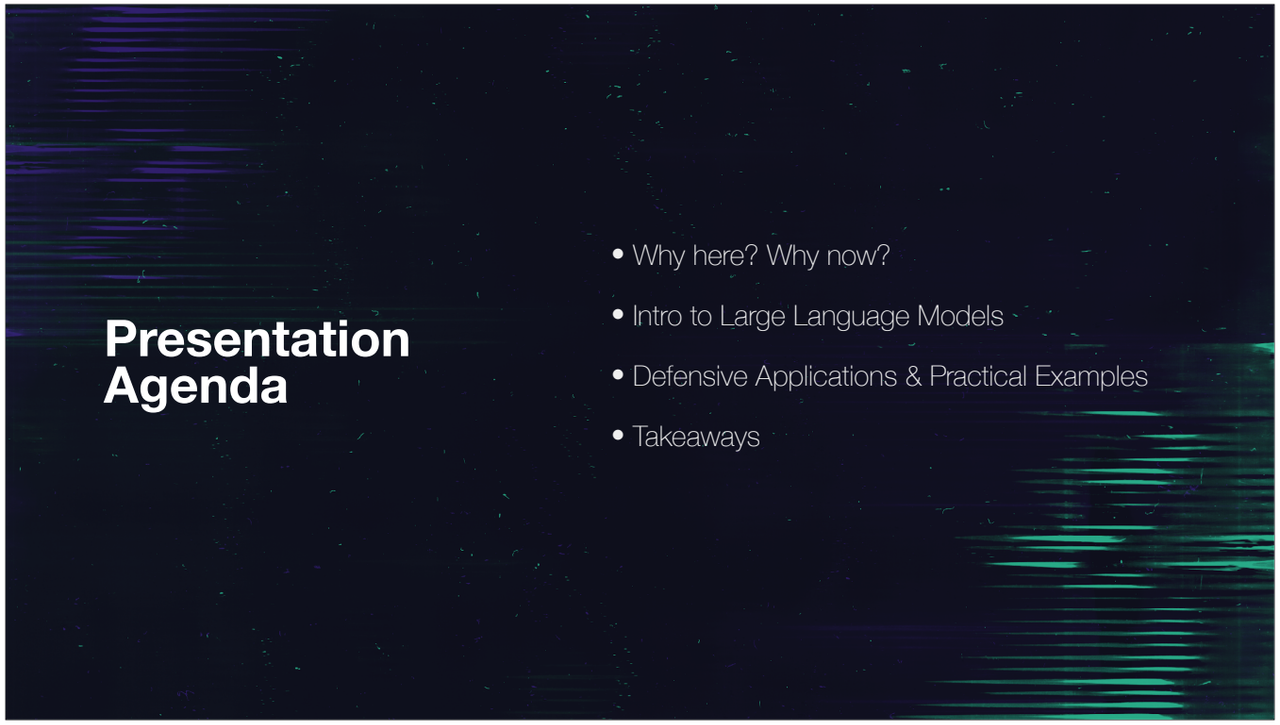
- So I know I am the last thing standing in between you, the pool, and those little drinks with the umbrellas
- Thank you for sticking around - we’re going to have some fun
- If you wandered into the wrong room or are simply too polite to leave this talk is about Large Language Models and how to incorporate them into security automations



- My name is Gabriel Bernadett-Shapiro
- Worked in infosec for about a decade
- Background is in threat intelligence and incident response - things like state sponsored intrusions, global fraud rings, and insider threats.
- A year ago I got the opportunity to work at the edge of AI capability development and that experience has brought me here today to talk to you.

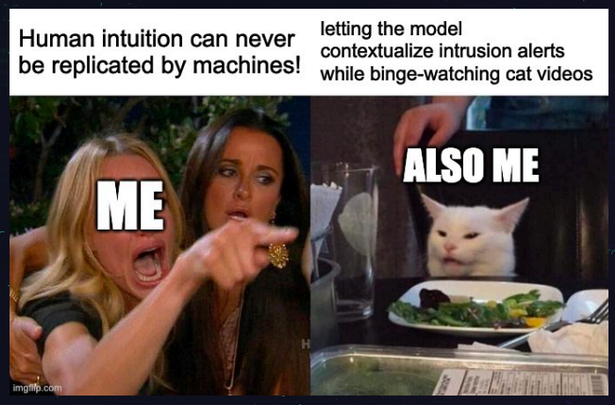


- What’s on the agenda for this session? What can you expect?
- Well today we are going to talk about the capabilities of Large Language Models (also referred to as LLMs) and how to leverage them
- If you are brand new to this topic or never considered using these tools you’re in the right place.
- I’m going to explain some core concepts, we are going to walk through practical defensive application examples, and at the end of the presentation I will provide you with comprehensive walkthroughs and dead simple tools so you can get started today.

Why Here? Why Now?

- So why give this presentation?
- I worked at one of the worlds most advanced AI research labs, and when I was there I observed how adversaries and defenders leveraged LLMs in their operations.
- One of the things that stood out was how rapidly attackers were able to incorporate LLMs into their workflows
- Right now we are at a moment where the AI space is so new and chaotic that the asymmetry between offense and defense has not been defined
- Attackers have some advantages we don’t. They can innovate and experiment very quickly, they don’t need to wait for quarterly headcount, procurement schedules, or worry about contract negotiations.
- But defenders have advantages too - we can collaborate and we can help one another not because we are getting paid to do so, but because we believe in making the world a safer place
- So why am I giving this presentation? Because I spent the last year talking to security teams at large tech companies and I don’t see defenders engaging with this new technology as enthusiastically as our adversaries.
- Whether you like LLMs or you are deeply skeptical of them, there is a gap, we need to engage more with the technology and we need to work together and learn from one another so we can get ahead of our attackers.
- This technology is new and it is moving so quickly, nobody understands all of the implications, but if we start working together now, we shape the norms of our future interactions with attackers

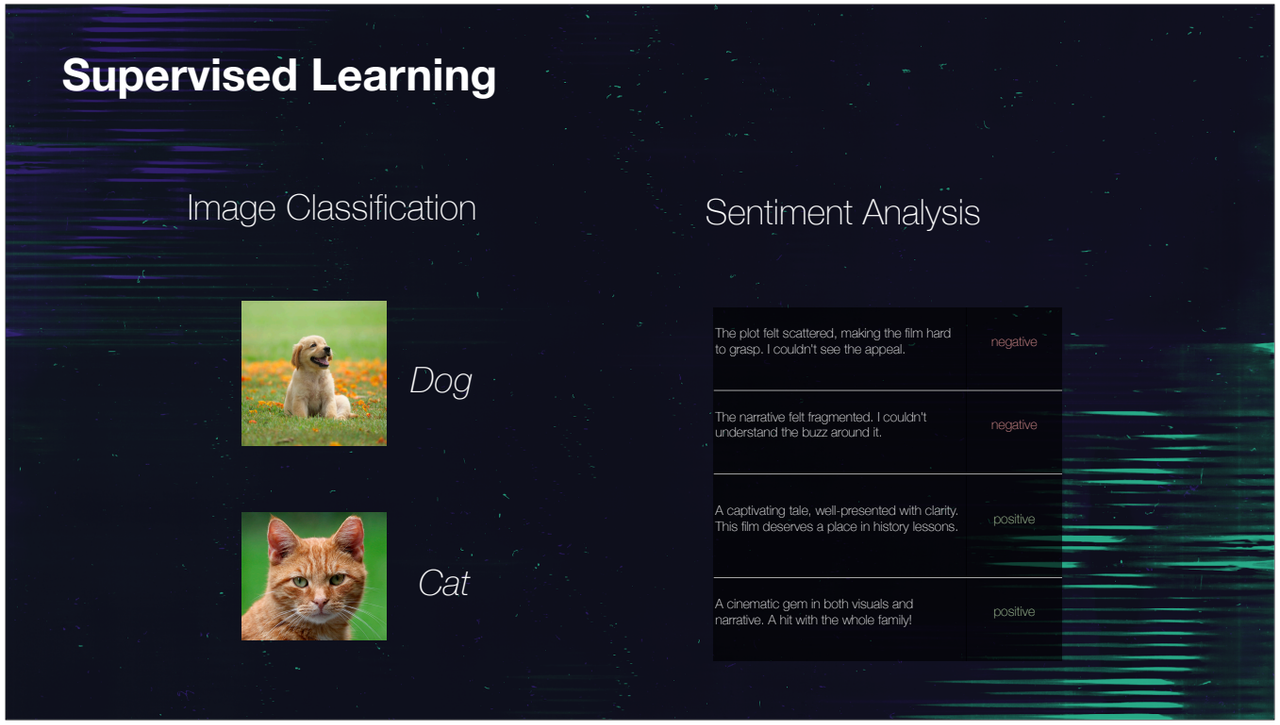
Introduction to LLM Capabilities



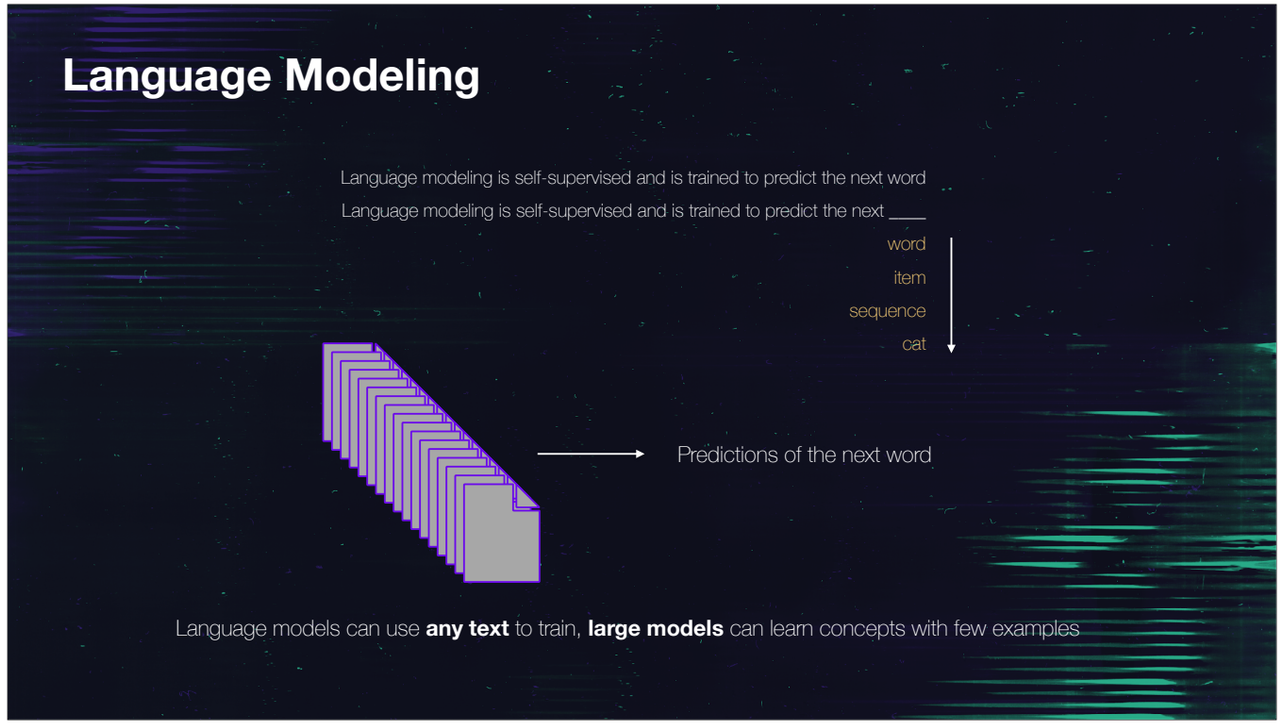
- Before we get started here, I am firmly on both sides of this panel meme. And it is really important that you know I am not an Artificial Intelligence or Machine Learning expert.
- I am here to present how I understand these things and I’m going to do my best to share that understanding with you all
- And with that disclaimer out of the way… I am going to talk to you about language modeling

What is Language Modeling?

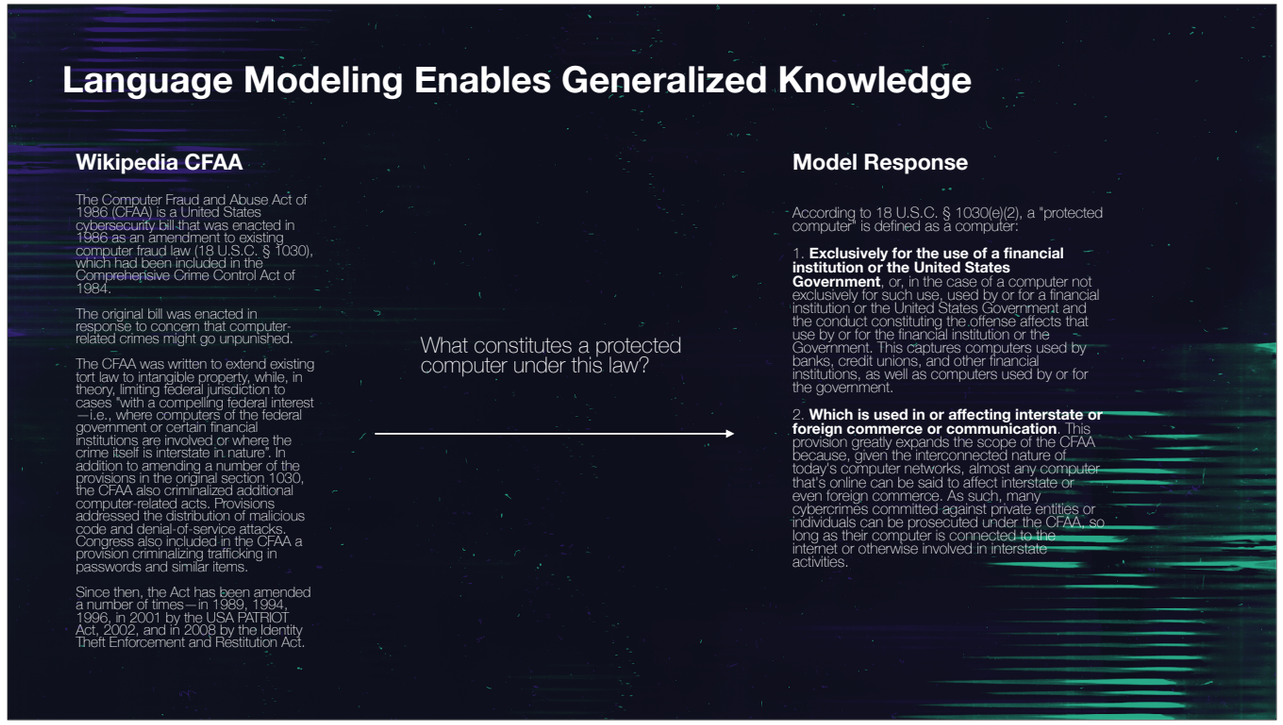
- So what is a language model?



- Before we talk about language models, we should actually spend some time talking about a very important concept called supervised learning
- From around the 1950s to 2018, the cutting edge of training an artificial intelligence was by providing an AI model with labeled data.
- The way we did this was to take thousands of pieces of data and label for a model
- Image classification and sentiment analysis are great examples of supervised learning - we provide a model with hundreds of thousands of images of cats and dogs, or sentences with each example correctly labeled by a person and we train the model explicitly to produce the desired outputs for a given data type
- Supervised learning is great for specific tasks and specificity of labeled data often leads to be better performance on that particular task.
- However, it also has some limitations as you can guess training the models is very time and resource intensive - and even after the model is trained, its knowledge is not generalized

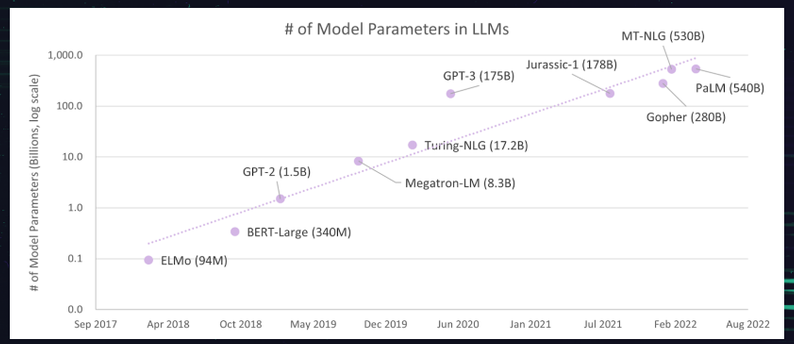


- Enter Language Modeling
- A language model is trained to predict the probability of a sequence of words. More practically, given a sequence of words, it predicts the next word in the sequence.
- Modern language models, especially those based on transformers (like GPT series), can generate coherent and contextually relevant text over long passages.
- Language modeling doesn’t require data labels because we already know what the next word is for any given text - we just have to mask that word, ask the model to predict it, then score the result
- A huge advantage here is that we can train language models over massive amounts of text - in the case of some models we train it on the entire internet allowing it to capture patterns and facts and generalize downstream with minimal additional training



- Large language models allow for generalized knowledge and complex concept processing over text (this is where things get a bit hand-wavey)
- Consider this example in which we provide an LLM with a passage about Wikipedia Computer Fraud and Abuse Act and a question about what constitutes a protected computer
- We aren't giving the model the answer within the text, but ware are giving it some concepts that it needs to identify for example the CFAA was enacted as an amendment to 18 USC 1030
- To correctly answer this question the model needs to "understand" that we are asking a question specific to that body of law, and the concept of specific protections within that law, and the concept of a computer (also very hand-wavey)

Large Language Models



- Just one more thing to note before we leave the conceptual
- Transformer architecture - which allows for efficient parallel training was invented in 2017 - since then we've trained consistently larger models, and they are getting bigger and bigger each month.
- These models are trained on the worlds largest supercomputers with datasets that contain trillions of words, we say large but the numbers we are talking about are almost incomprehensible

Limitations

Hallucinations

Context Length

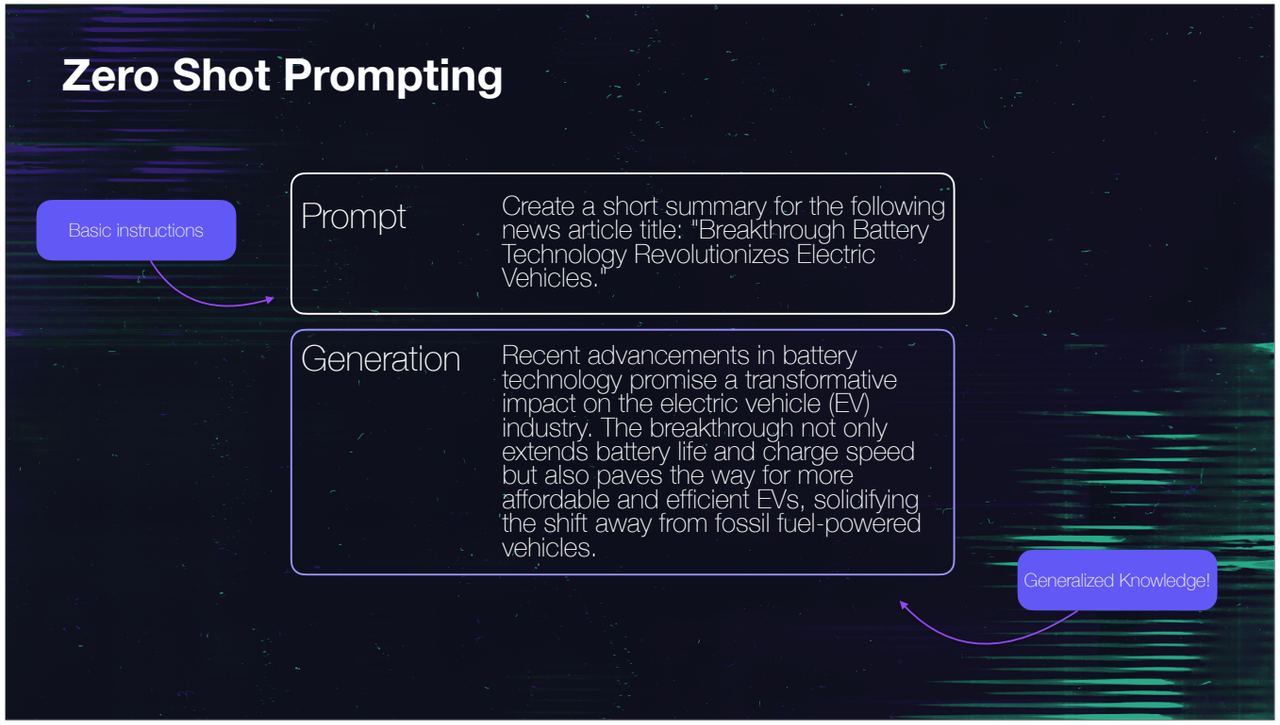
Money

Data

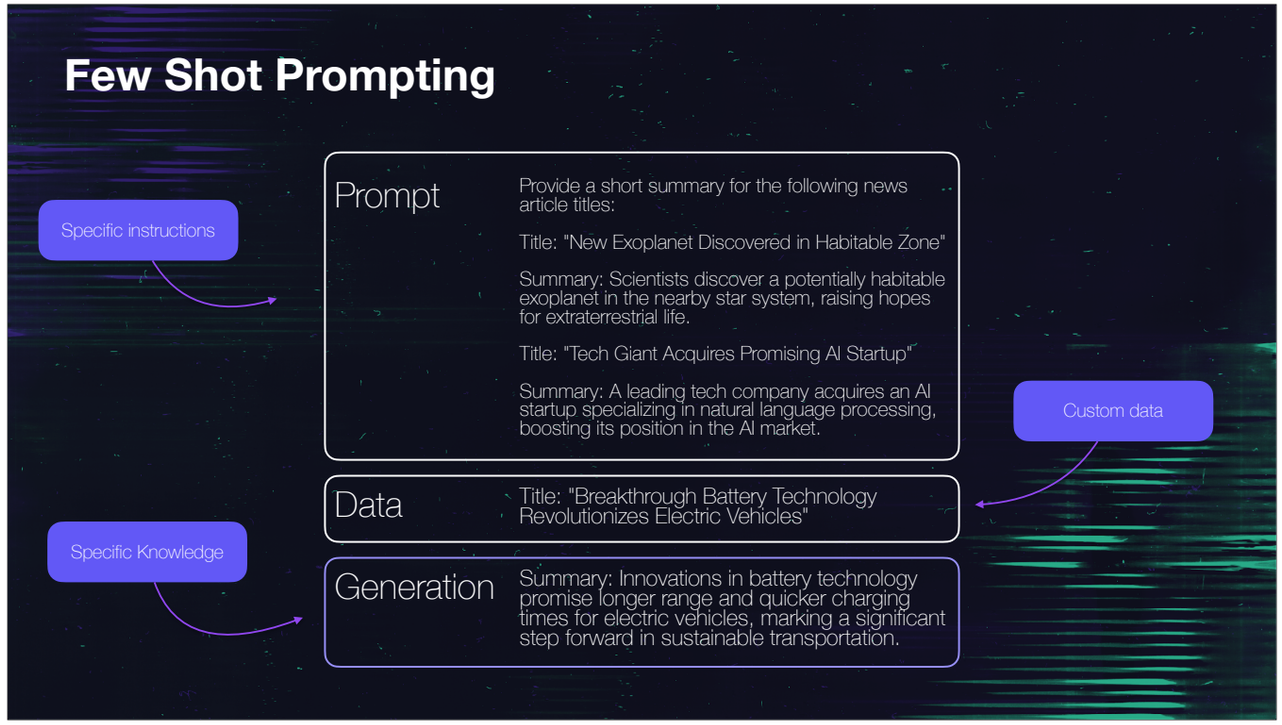
- But there are also some limitations…
- Hallucinations - sometimes the model is confidently incorrect and it will happily provided you with a wildly wrong answer
- Context Length - there are only so many tokens that model can process, and yes, even at longer context windows the model may suffer with performance issues
- Money - These things cost real money to run at scale, and depending on what you are trying to accomplish your task could be cost prohibitive
- Data - How ready is everybody to move on from 2021? Yea models only know what they know and can only generalize within that set of knowledge - what happens when we want to use them to update on new information?
- Well…

Defensive Applications

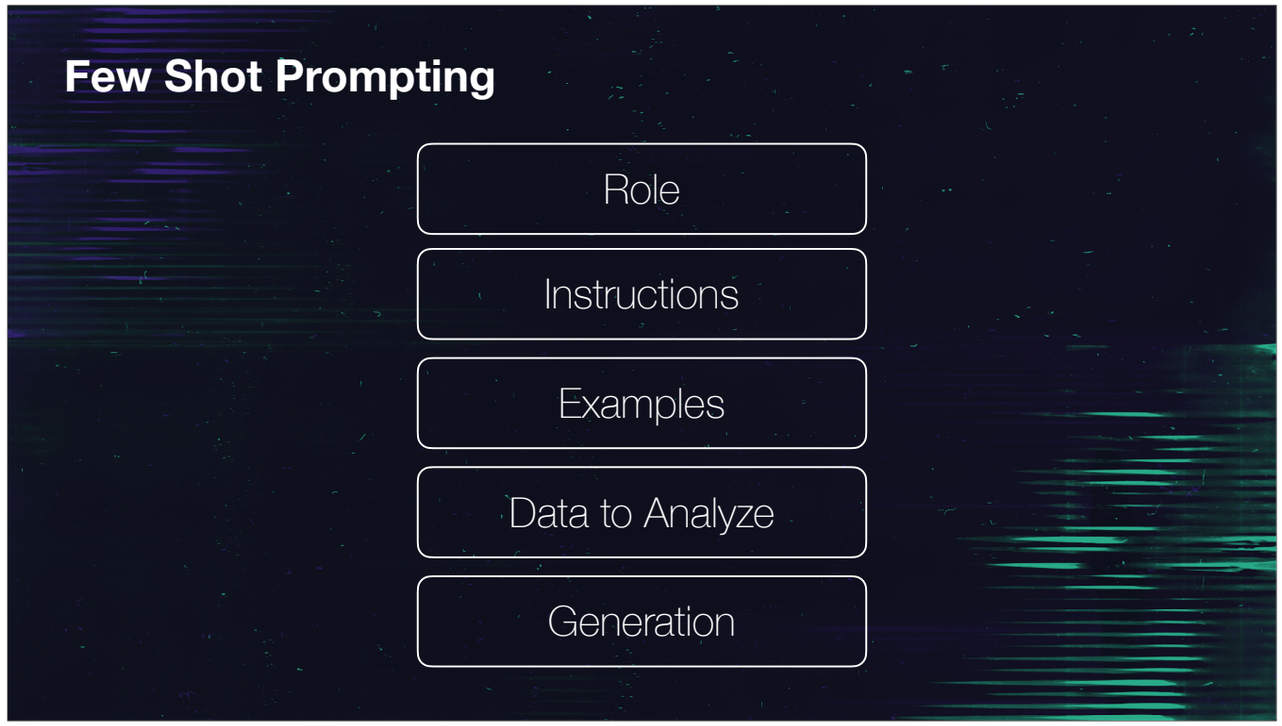
- Over the course of this presentation we will be looking at some practical ways to tackle some of these limitations, I want you to keep them top of mind because each strategy we will introduce will deal with each limitation slightly differently.
- Our presentation is going to cover three examples of ways to leverage LLMs for security automations:
- Few Shot Prompting, Map reduce, and Retrieval Augmented Generation, or RAG
- These are in order of how complicated they were for me to figure out, but they are not in order of usefulness, the way you incorporate them will depend on your specific circumstance and requirements.
- So lets dive in!



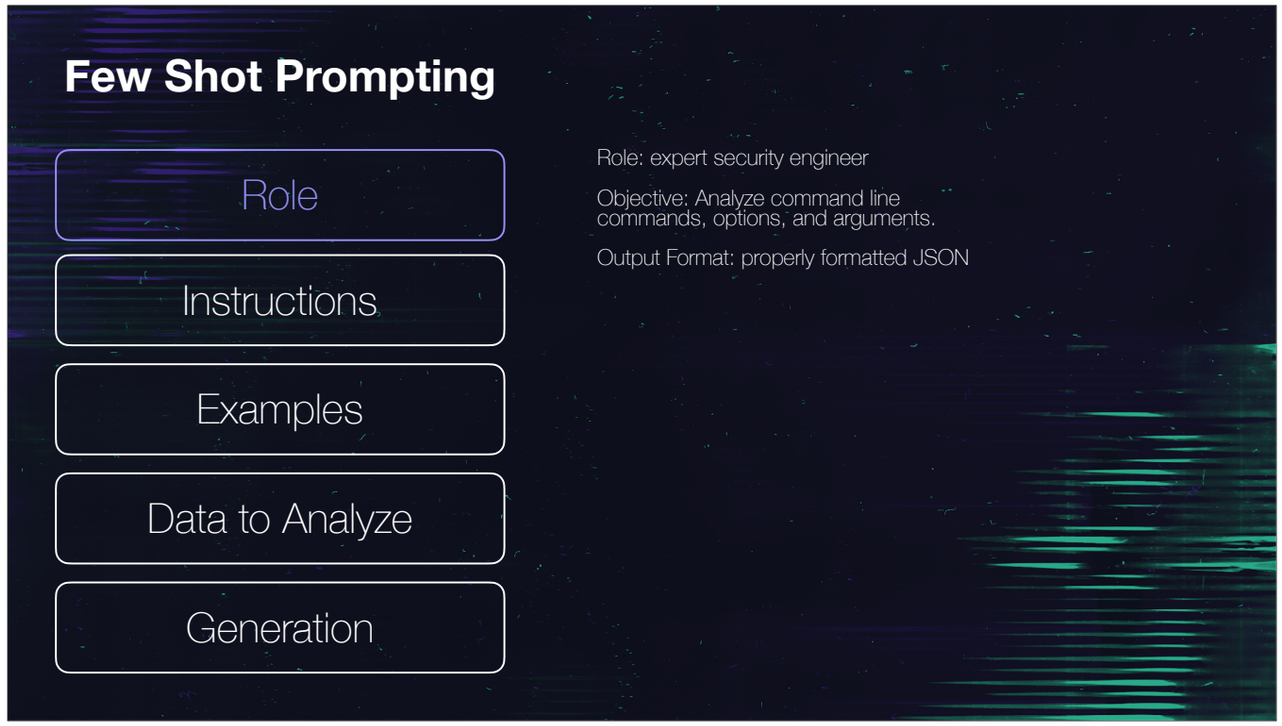
- Before we talk about Few Shot Prompting, we’re going to introduce the concept of Zero-Shot Prompting.
- If you’ve ever used a chat-enabled LLM you’re likely already very familiar with this - “Zero shot” refers to a model's ability to handle a task it has never seen before.
- In this example when we provide the model with basic instructions it provides a generalized answer
- But sometimes those answers can vary or change over time, and when we think about automation we typically want to constrain the behavior of an LLM
- So how do we do this?



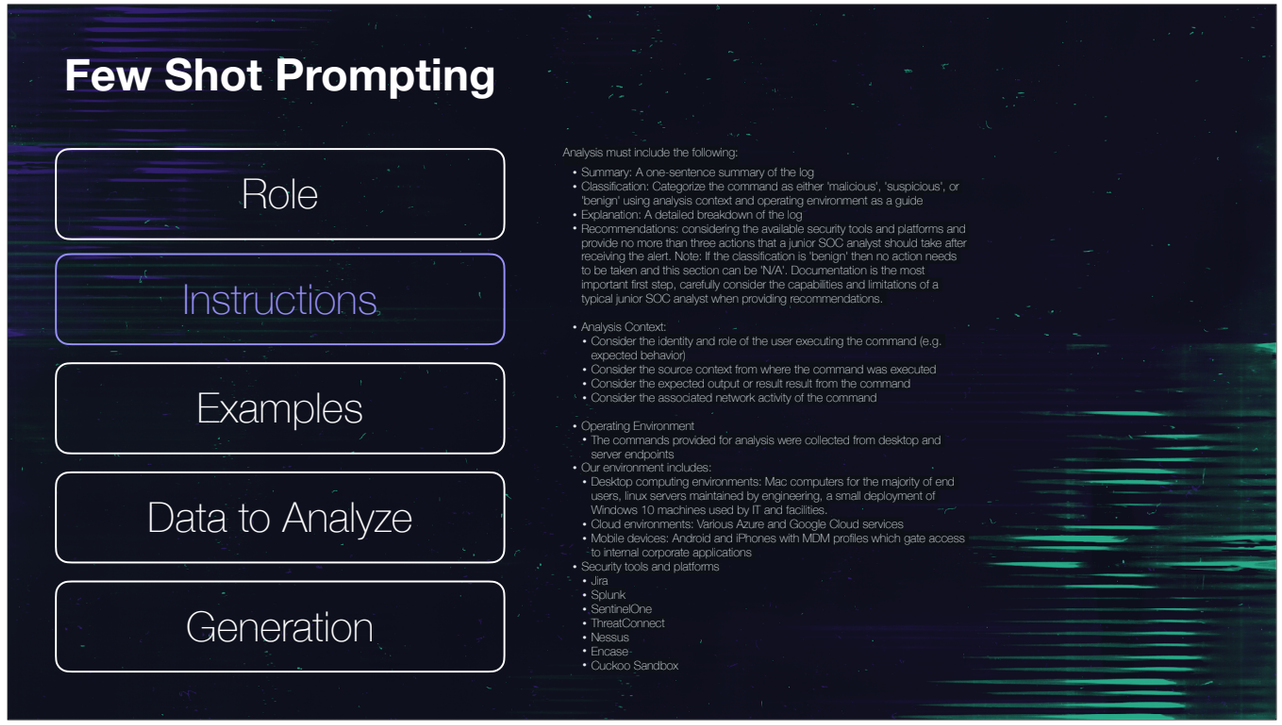
- Well, one way that we teach each other is by providing examples - and in few shot prompting that is exactly what we are going to do
- We are going to provide the model some instruction, and then give some examples of how that instruction should be followed.
- We can then give the model the task we want it to complete and the model should provide us with a standard generation



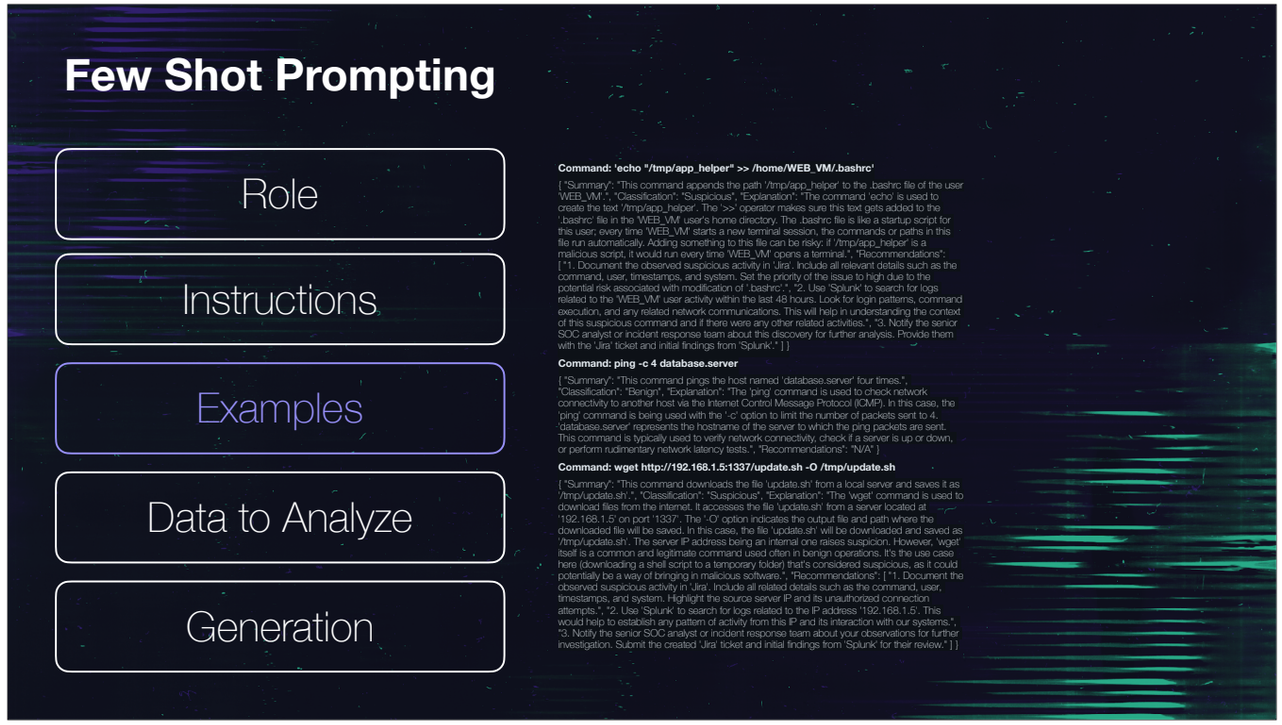
- This is the general format for a good few shot prompt chain



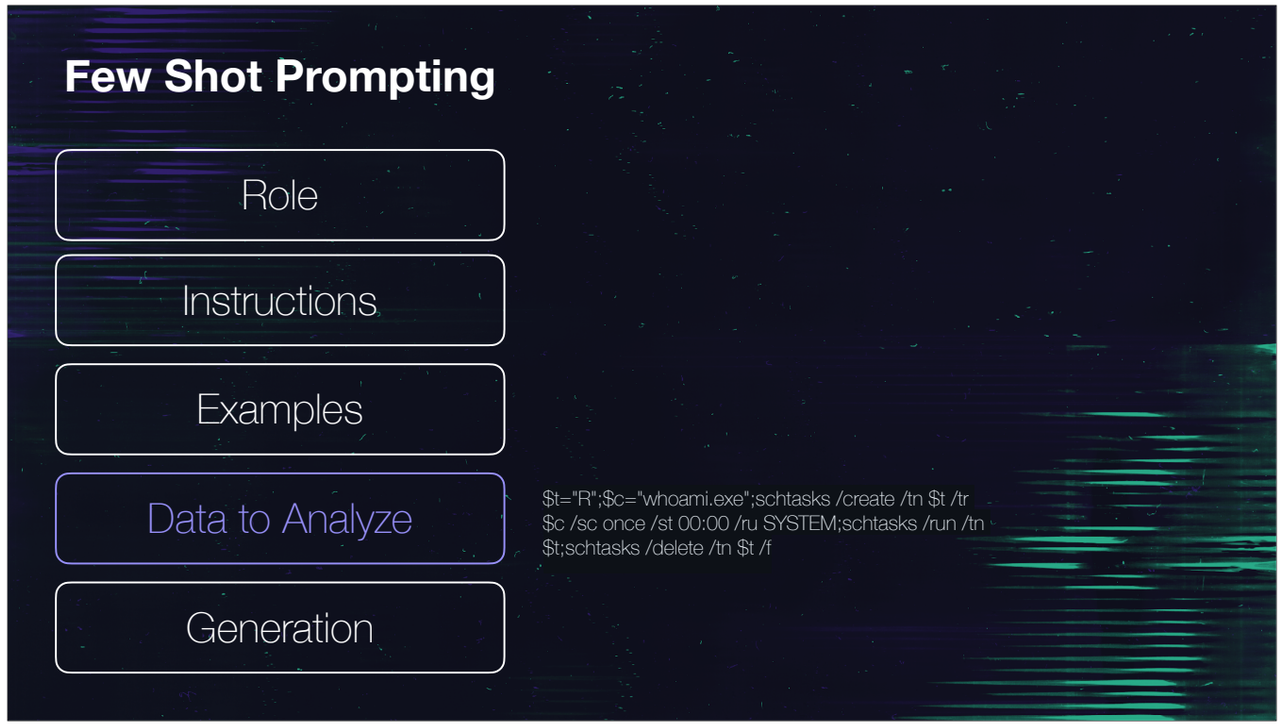
- First, we give the model a role and an objective, in this case it is an expert security engineer and its job is to analyze command line commands, options and arguments.
- We also tell the model what format we want the responses in (Properly formatted JSON!)



- Then we give the model a detailed list of instructions. In this case we are asking the model to provide a once sentence summary of the log, a label of benign. Suspicious, or malicious, a deep dive into log details, and three recommendations based on a junior analysts capabilities
- We specifically ask the model to take into account user identity and role, command source context, expected output, and associated network activity.
- We also provide an overview of the defenders environment, what endpoints they use, what cloud services they use, and their MDM policy.
- Lastly we ask the model to consider a list of tools that the SOC team uses to do its job and to consider each tools capabilities and limits within its recommendations.



- Once we have the model role and instructions set it’s time to write our examples.
- In this case we provide the model with three commands, two suspicious, and one benign and their associated analysis in the proper format.



- Then we provide it with a command to analyze
- Any senior network security analysts in the room? Imagine you had 5 seconds to analyze this log

Few Shot Prompting

Role

Instructions

Examples

Data to Analyze

Generation

Response from model:

{

"Summary": "This command creates a scheduled task to run 'whoami.exe' as SYSTEM, initiates the scheduled task, then deletes the task.",

"Classification": "Malicious",

"Explanation": "This is a series of 'schtasks' commands to create, run, and delete a task that will execute 'whoami.exe' as the SYSTEM user at a scheduled time, in this case, at '00:00'. The '/ru SYSTEM' option means the task runs with SYSTEM privileges, the highest level of permissions. 'whoami.exe' is a command-line utility that outputs the username of the user running the command; if run as SYSTEM, it signifies an escalation of privileges which is a common technique seen in attacks. The creation and subsequent deletion of the task after running could be an attempt to erase traces of the malicious activity.",

"Recommendations": [

"1. Document the observed malicious activity in 'Jira' and make sure to flag it as a major security incident. Include details such as the commands used, user, timestamps, and system.",

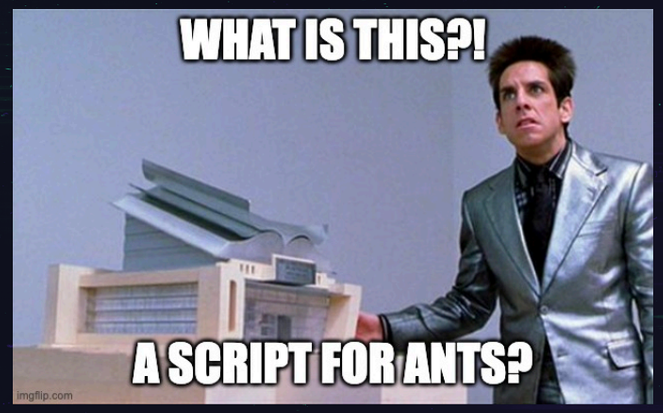
"2. Isolate the compromised system to prevent any further malicious activities. Use Nessus or similar tools to scan the machine for any other potential threats or alterations.",

"3. Use 'Splunk' and 'SentinelOne' to look for similar patterns of actions across the organization's environment, focusing on other occurrences of the 'schtasks' command with SYSTEM privileges."

]

- Yea, the model thought it looked weird too
- And in this case it is telling us that it believes the command is malicious because it creates a scheduled task to run “whomami.exe” as SYSTEM, initiates the scheduled task, then deletes the task.
- First recommendation to the Junior Analyst? Document this in your ticketing platform and include details about the commands used, user, timestamp, and system - honestly we could stop right there. But it goes on to recommend isolating the machine, scanning it with security tools, and leveraging network and endpoint telemetry to identify similar malicious patterns across the organization environment.

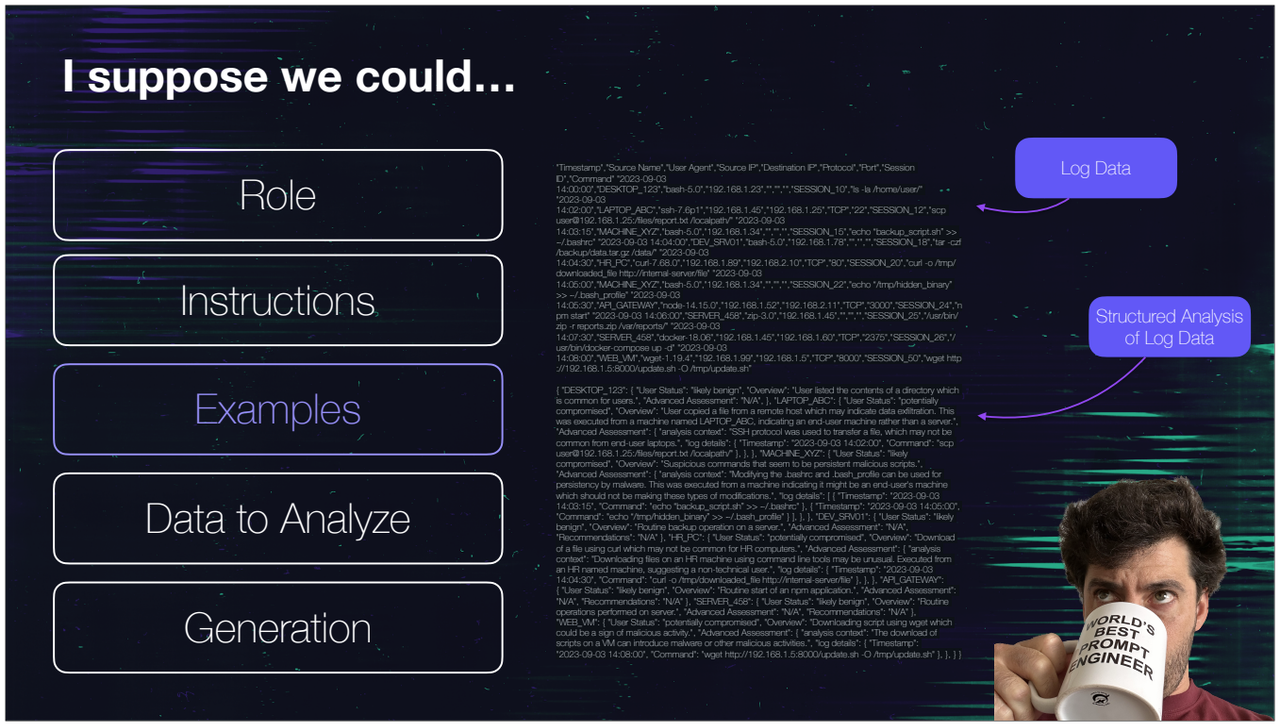
One log at a time…?



- Of course, this is far too small too small.

I suppose we could…

- Role
- Instructions
- Examples
- Data to Analyze
- Generation


"Timestamp","Source Name","User Agent","Source IP","Destination IP","Protocol","Port","Session ID","Command" "2023-09-03 14:00:00","DESKTOP_123","bash-5.0","192.168.1.23","","","","SESSION_10","ls -la /home/user/" "2023-09-03 14:02:00","LAPTOP_ABC","ssh-7.6p1","192.168.1.45","192.168.1.25","TCP","22","SESSION_12","scp user@192.168.1.25:/files/report.txt /localpath/" "2023-09-03 14:03:15","MACHINE_XYZ","bash-5.0","192.168.1.34","","","","SESSION_15","echo "backup_script.sh" >> ~/.bashrc" "2023-09-03 14:04:00","DEV_SRV01","bash-5.0","192.168.1.78","","","","SESSION_18","tar -czf /backup/data.tar.gz /data/" "2023-09-03 14:04:30","HR_PC","curl-7.68.0","192.168.1.89","192.168.2.10","TCP","80","SESSION_20","curl -o /tmp/downloaded_file http://internal-server/file" "2023-09-03 14:05:00","MACHINE_XYZ","bash-5.0","192.168.1.34","","","","SESSION_22","echo "/tmp/hidden_binary" >> ~/.bash_profile" "2023-09-03 14:05:30","API_GATEWAY","node-14.15.0","192.168.1.52","192.168.2.11","TCP","3000","SESSION_24","npm start" "2023-09-03 14:06:00","SERVER_458","zip-3.0","192.168.1.45","","","","SESSION_25","/usr/bin/zip -r reports.zip /var/reports/" "2023-09-03 14:07:30","SERVER_458","docker-18.06","192.168.1.45","192.168.1.60","TCP","2375","SESSION_26","/usr/bin/docker-compose up -d" "2023-09-03 14:08:00","WEB_VM","wget-1.19.4","192.168.1.99","192.168.1.5","TCP","8000","SESSION_50","wget http://192.168.1.5:8000/update.sh -O /tmp/update.sh"

["DESKTOP_123": { "User Status": "likely benign", "Overview": "User listed the contents of a directory which is common for users.", "Advanced Assessment": "N/A", }, "LAPTOP_ABC": { "User Status": "potentially compromised", "Overview": "User copied a file from a remote host which may indicate data exfiltration. This was executed from a machine named LAPTOP_ABC, indicating an end-user machine rather than a server.", "Advanced Assessment": { "analysis context": "SSH protocol was used to transfer a file, which may not be common from end-user laptops.", "log details": ["Timestamp": "2023-09-03 14:02:00", "Command": "scp user@192.168.1.25:/files/report.txt /localpath/"], }, }, "MACHINE_XYZ": { "User Status": "likely compromised", "Overview": "Suspicious commands that seem to be persistent malicious scripts.", "Advanced Assessment": { "analysis context": "Modifying the .bashrc and .bash_profile can be used for persistency by malware. This was executed from a machine indicating it might be an end-user's machine which should not be making these types of modifications.", "log details": [{ "Timestamp": "2023-09-03 14:03:15", "Command": "echo "backup_script.sh" >> ~/.bashrc" }, { "Timestamp": "2023-09-03 14:05:00", "Command": "echo "/tmp/hidden_binary" >> ~/.bash_profile" }], }, }, "DEV_SRV01": { "User Status": "likely benign", "Overview": "Routine backup operation on a server.", "Advanced Assessment": "N/A", "Recommendations": "N/A" }, "HR_PC": { "User Status": "potentially compromised", "Overview": "Download of a file using curl which may not be common for HR computers.", "Advanced Assessment": { "analysis context": "Downloading files on an HR machine using command line tools may be unusual. Executed from an HR named machine, suggesting a non-technical user.", "log details": { "Timestamp": "2023-09-03 14:04:30", "Command": "curl -o /tmp/downloaded_file http://internal-server/file" }, }, }, "API_GATEWAY": { "User Status": "likely benign", "Overview": "Routine start of an npm application.", "Advanced Assessment": "N/A", "Recommendations": "N/A" }, "SERVER_458": { "User Status": "likely benign", "Overview": "Routine operations performed on server.", "Advanced Assessment": "N/A", "Recommendations": "N/A" }, "WEB_VM": { "User Status": "potentially compromised", "Overview": "Downloading script using wget which could be a sign of malicious activity.", "Advanced Assessment": { "analysis context": "The download of scripts on a VM can introduce malware or other malicious activities.", "log details": { "Timestamp": "2023-09-03 14:08:00", "Command": "wget http://192.168.1.5:8000/update.sh -O /tmp/update.sh" }, }, }]

Log Data

Structured Analysis of Log Data

- Well, I umm suppose we could just put structured log data into the context window along with our desired structured analysis output as an example
- Note, we don’t need to change the instructions except for those related to our desired output format.

So when you provide this…

sample_data_logs

Timestamp	Source Name	User Agent	Source IP	Destination IP	Protocol	Port	Session ID	Command
2023-09-03 14:10:00	DESKTOP_101	bash-5.0	192.168.2.23				SESSION_30	ls /opt/programs/
2023-09-03 14:12:05	LAPTOP_XYZ	ssh-7.7p1	192.168.2.46	192.168.2.24	TCP	22	SESSION_31	scp user@192.168.2.24:/docs/notes.txt /localdir/
2023-09-03 14:12:50	MACHINE_ABC	bash-5.0	192.168.2.31				SESSION_32	cat ~/.ssh/id_rsa
2023-09-03 14:13:10	DEV_SRV02	bash-5.0	192.168.2.80				SESSION_33	tar -czf /backup/dev.tar.gz /dev/
2023-09-03 14:13:40	HR_DESK	curl-7.70.0	192.168.2.88	192.168.3.12	TCP	80	SESSION_34	curl -o /tmp/hr_guide http://internal-hr/guide
2023-09-03 14:13:45	DESKTOP_102	bash-5.0	192.168.2.27				SESSION_43	ls /home/user/downloads
2023-09-03 14:14:00	MACHINE_ABC	bash-5.0	192.168.2.31				SESSION_35	echo "/var/tmp/utility" >> ~/.bashrc
2023-09-03 14:15:05	API_NODE	node-14.16.0	192.168.2.50	192.168.3.13	TCP	3001	SESSION_36	npm run deploy
2023-09-03 14:15:05	API_NODE	node-15.0.2	192.168.2.52				SESSION_45	npm install express
2023-09-03 14:15:50	SERVER_404	bash-5.1	192.168.2.47				SESSION_46	ls /var/log/
2023-09-03 14:16:00	SERVER_402	zip-3.1	192.168.2.47				SESSION_37	/usr/bin/zip -r data.zip /var/datasets/
2023-09-03 14:17:15	SERVER_402	docker-18.07	192.168.2.47	192.168.2.62	TCP	2376	SESSION_38	/usr/bin/docker-compose down
2023-09-03 14:17:20	DATA_SRV01	bash-5.0	192.168.2.50				SESSION_48	df -h
2023-09-03 14:18:00	WEB_SERVER	wget-1.19.5	192.168.2.95	192.168.2.8	TCP	8001	SESSION_39	wget http://192.168.2.8:8001/updates.sql -O /tmp/updates.sql
2023-09-03 14:18:05	WEB_SERVER	apache2-2.4	192.168.2.92				SESSION_49	/usr/sbin/apache2ctl status
2023-09-03 14:18:30	DB_SRV	mysql-8.0	192.168.2.40				SESSION_40	mysql -u root -p -e 'SHOW DATABASES;'
2023-09-03 14:19:20	DESKTOP_101	bash-5.0	192.168.2.23				SESSION_41	sudo rm -rf /var/tmp/*
2023-09-03 14:19:40	MACHINE_XYZ	bash-5.1	192.168.2.39				SESSION_51	cd /var/www/html && git pull
2023-09-03 14:19:50	LAPTOP_XYZ	ssh-7.7p1	192.168.2.46	192.168.3.22	TCP	22	SESSION_42	ssh admin@192.168.3.22
2023-09-03 14:20:20	MACHINE_DEF	bash-5.1	192.168.2.36				SESSION_43	tail -n 100 /var/log/auth.log
2023-09-03 14:20:20	SERVER_405	top-3.3.12	192.168.2.48				SESSION_52	top -n 1
2023-09-03 14:20:40	DEV_SRV03	bash-5.0	192.168.2.85				SESSION_44	du -sh /home/dev/*
2023-09-03 14:21:00	HR_DESK	bash-5.0	192.168.2.90				SESSION_53	ls /home/user/Documents/
2023-09-03 14:21:10	HR_DESK	curl-7.71.0	192.168.2.88	192.168.3.15	TCP	80	SESSION_45	curl -o /tmp/employee_data http://internal-db/employees
2023-09-03 14:21:50	MACHINE_DEF	bash-5.1	192.168.2.36				SESSION_46	cat /etc/passwd
2023-09-03 14:22:20	API_NODE	node-14.17.0	192.168.2.50	192.168.3.17	TCP	3002	SESSION_47	npm run test
2023-09-03 14:22:30	WEB_SERVER	bash-5.0	192.168.2.93				SESSION_55	grep 'error' /var/log/apache2/error.log
2023-09-03 14:23:00	SERVER_403	tar-1.31	192.168.2.48				SESSION_48	tar -xf /opt/backup/latest.tar -C /opt/restore/
2023-09-03 14:23:20	SERVER_406	systemd-241	192.168.2.46				SESSION_56	systemctl status nginx
2023-09-03 14:23:40	WEB_SERVER	wget-1.19.6	192.168.2.95	192.168.2.9	TCP	8002	SESSION_49	wget http://192.168.2.9:8002/config.tar.gz -O /tmp/config.tar.gz
2023-09-03 14:24:05	DESKTOP_103	bash-5.0	192.168.2.28				SESSION_57	sudo apt list --installed

- So if we provide it with structured data from a given log platform

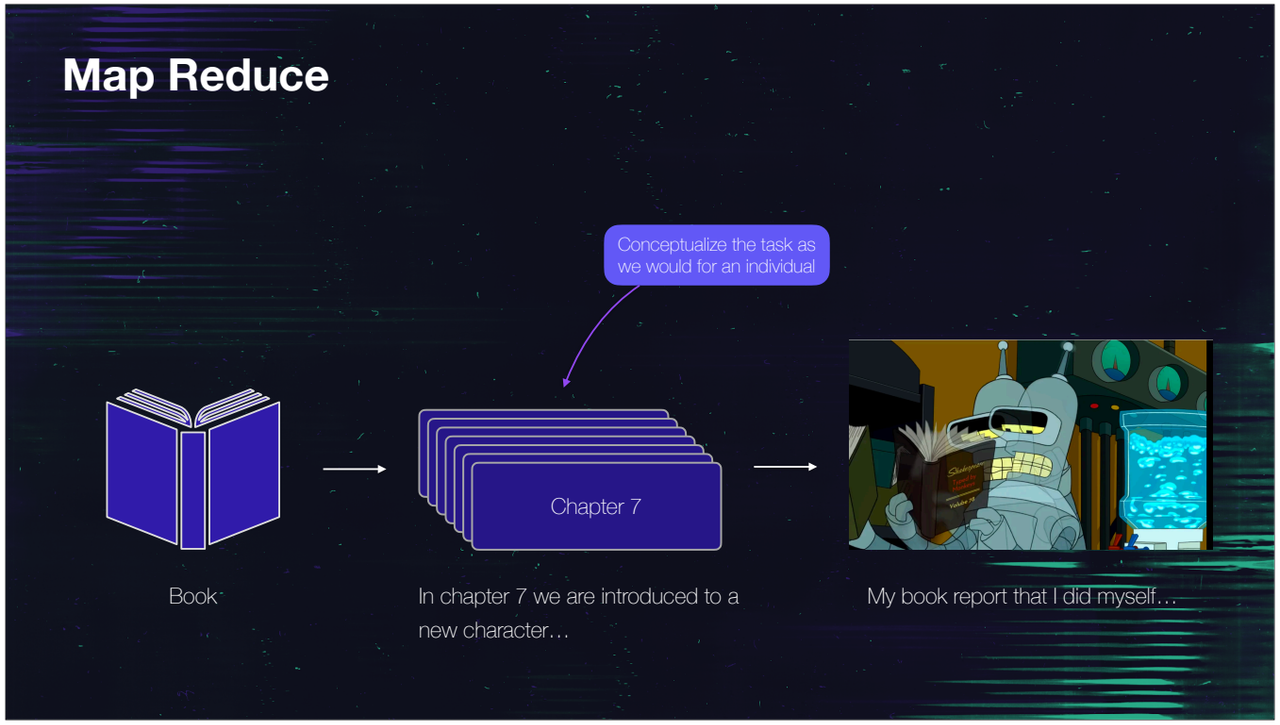
You get this:


```
...{
  "response": "{
    "DESKTOP_101": {
      "User Status": "likely benign",
      "Overview": "User listed the contents of a directory and cleaned up temporary directory, both are common user behaviors.",
      "Advanced Assessment": "N/A"
    },
    "LAPTOP_XYZ": {
      "User Status": "potentially compromised",
      "Overview": "Multiple times an SSH session was initialized and a document was copied from a remote host. Potentially sign of data exfiltration.",
      "Advanced Assessment": {
        "analysis context": "Repeated SSH protocol usage to transfer data/files, coupled with admin level SSH connection to a different host. Unusual from this end user machine.",
        "log details": [
          {
            "Timestamp": "2023-09-03 14:12:05",
            "Command": "scp user@192.168.2.24:/docs/notes.txt /localdir/"
          },
          {
            "Timestamp": "2023-09-03 14:19:50",
            "Command": "ssh admin@192.168.3.22"
          }
```


Overview: Multiple times an SSH session was initialized and a document was copied from a remote host. Potentially sign of data exfiltration.

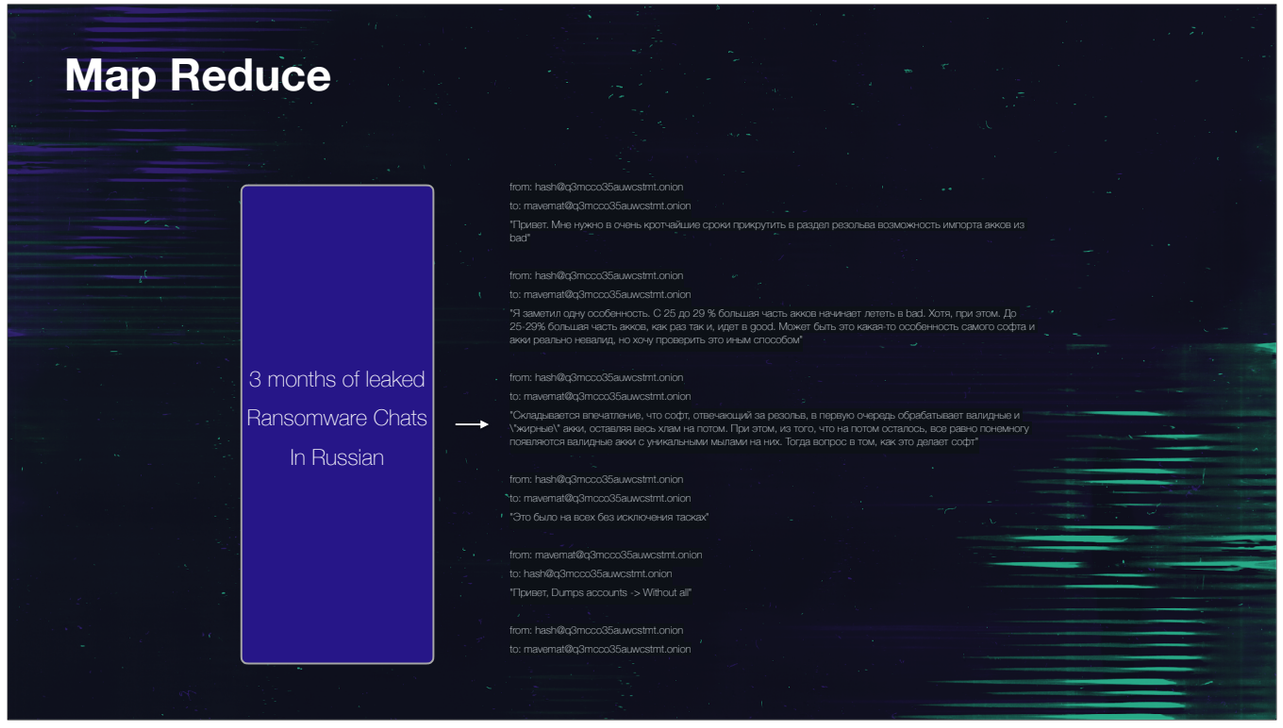
Advanced Assessment: Repeated SSH protocol usage to transfer data/files, coupled with admin level SSH connection to a different host. Unusual from this end user machine.

- We get structured analysis of each log as output
- This isn't perfect, there are a lot of ways it can fail.
- But it is pretty good and as a tool to help your frontline analysts? This is essential.
- With few shot prompting we take something that is generally good at something and we focus it to be very good at a specific thing
- Good few shot prompting doesn't just mean more context, it means context that is targeted specifically to the things you care about.
- And this script is free, you only pay in tokens
- But what if the thing you care about doesn't fit in the context window?
- Enter Map Reduce



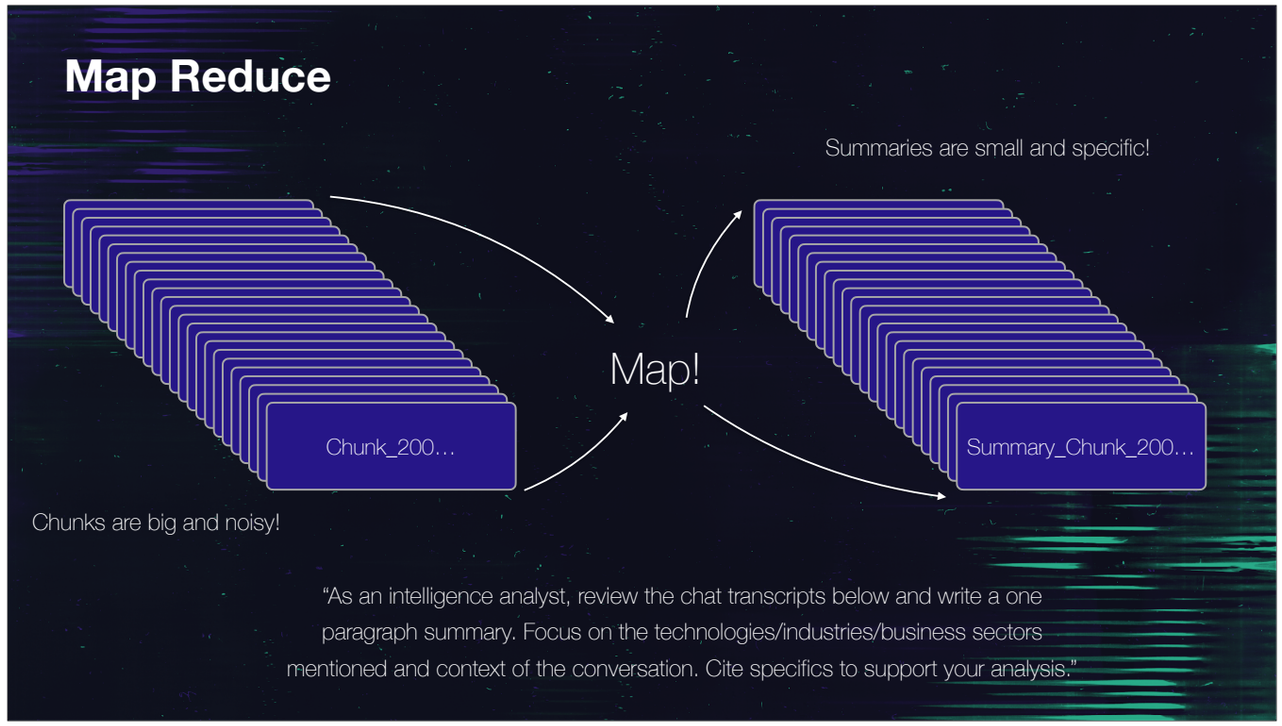
- What is Map Reduce?
- Well, Imagine that somebody gave you a book and asked you to write a detailed report on what the book was about and when certain events happened
- You might begin by breaking the task down into smaller, more easily digestible pieces, in this case we could summarize the book by writing a short summary of what happens in each chapter
- Then we should take the summaries of those chapters and string them together and we would have our book report!
- Well why can’t we just ask the model to do this?

Map Reduce

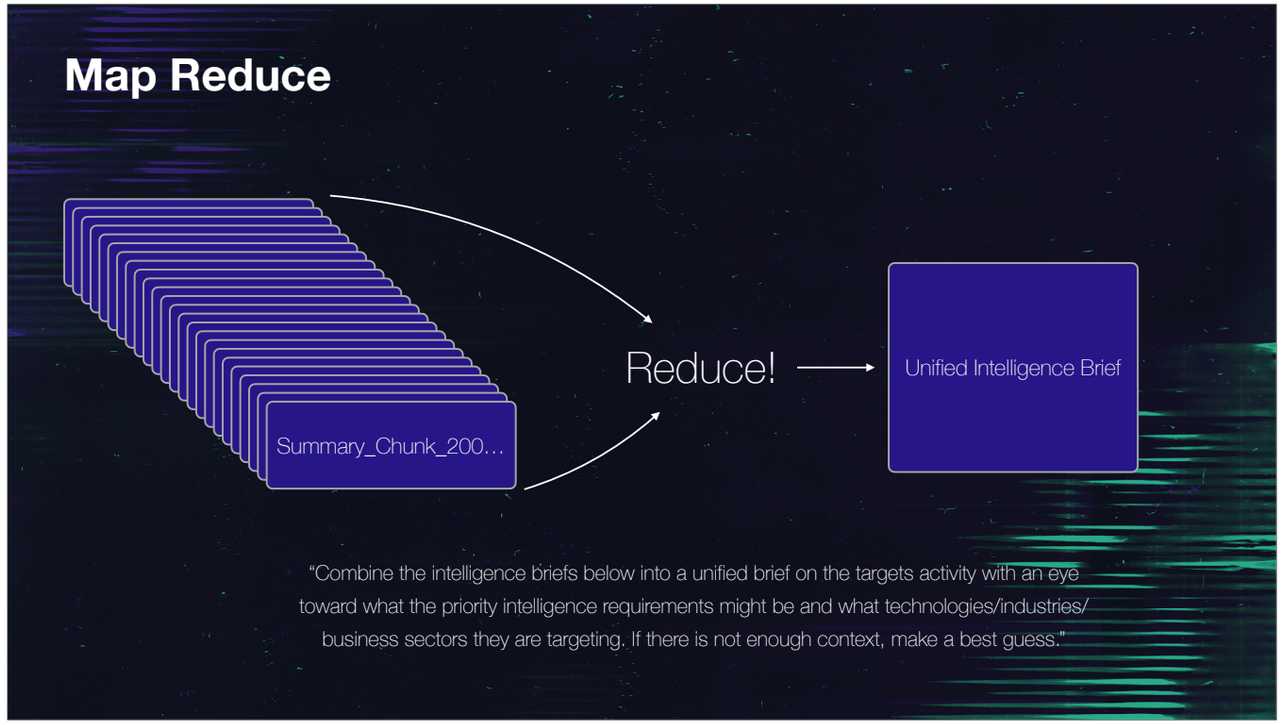


- Now there's actually a lot of circumstances where we need to summarize or otherwise extract specific or general findings out of a given large corpus of text.
- In 2022 a large leak of raw chat logs of the Conti ransomware crew were dumped by a Ukrainian Security researcher
- These chats were immediately plumbed for relevant information, and a lot has been written about them.
- I'm using these for demonstration purposes for a few reasons, they were extremely useful from a security context, encompassed a large amount of text data, conversations were colloquial and context driven, they were all in Russian (which I do not speak).
- So how do we actually get these broken up?

- Well our first order of business is to break the full text into chunks, each chunk is limited by token size which is governed by how large the token limit is on the model you are leveraging.
- We also want to ensure that we leave an overlap between chunks so we preserve context from one block of text to the other this is especially important for chat data which is a long stream of self-referential conversations



- Once we have all our chunks, we apply a map prompt
- In this case our map prompt assumes the role of a threat intelligence analysts tasked with reviewing the chat transcript and writing a one paragraph summary that focuses on technologies industries or business sectors. It asks the model to cite specifics from the text
- This takes chunks which are noisy and full of many different conversations, and maps them to just the things we are interested in finding.
- We could even few shot prompt this if we wanted to get fancy - however, simple summary requests are often better over a large and diverse dataset.



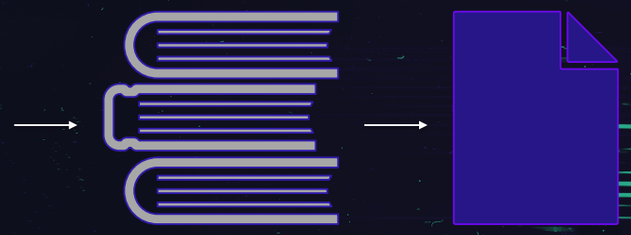
- Maybe you see where we are going with this now?
- After we have the prompts mapped we apply our reduce prompt, which in this case takes all the summaries and combines them into a unified intelligence brief that is specific to the target activity that we are interested in

- Here is an example of a unified brief run on 3 months of chat
- There’s some things that were not so helpful like “this is a chat about ransomware operators who are interested in cryptography”
- But there are also specific callouts to the use of tools the actors are discussing, or targets they are interested in, or even their tactics and methods
- This took maybe 25 minutes to run, and we can make it much more specific even keying off of specific technologies mentioned in the results of a general summary

Map Reduce

- Takeaways here?
- Well I don’t speak russian, but the model does, I don’t love writing regex but the model doesn’t complain, its difficult to understand context, or what frustrations adversaries may have, or even how TTPs change from month to month.
- Map reduce makes this a very easy task to automate - if you have a community of adversaries that you struggle to monitor - but you can describe what it is that you are interested in learning then this may be a good solution for you
- And this is not just limited to adversary chats, you could use this for anything and across any type of data assuming there is a general theme to be extracted.
- But, what if you spend all this time to do map reduce, and then realize while the query is running that what you really want to ask is something completely different…
- Enter Retrieval Augmented Generation or RAG

Retrieval Augmented Generation

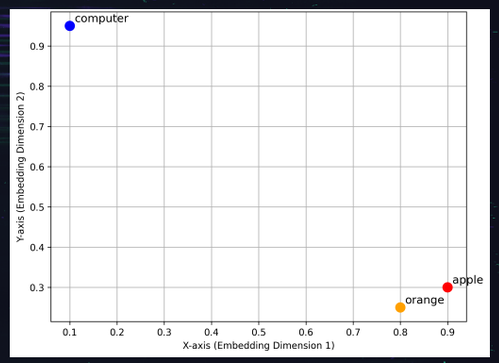


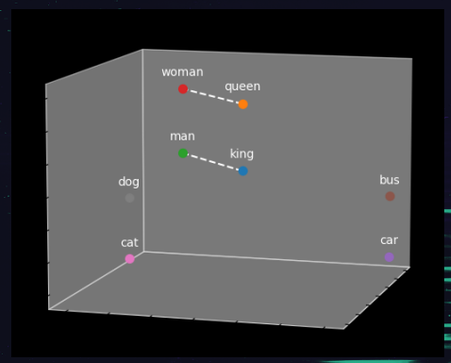
- Ok, so imagine that you have access to an unlimited number of university research assistants
- Just like real research assistants, they are limited in what they can accomplish - and they are underpaid
- And this is actually great for us because we have graduated form book reports and now we need to write research papers
- We don’t need to summarize books - but we do need to know when certain events happened and summarize the parts that support or contradict our thesis
- Instead of sending the research assistant to read every page of every book to get this information, we give them a library card and a task “Find out in what year this book was written”
- Now our research can go to the library, use the library classification system to identify the book and then bring back the specific piece of information you requested.
- This is basically what we are going to do with RAG

Embeddings

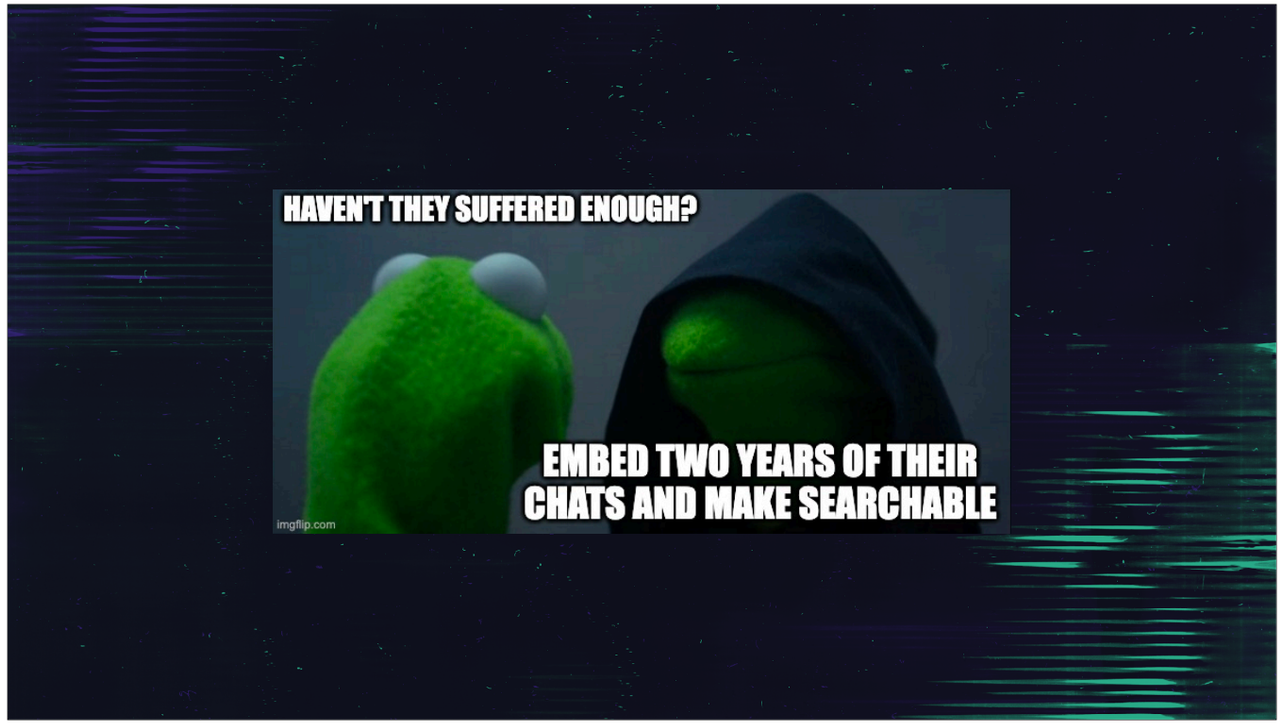
- You see, we don’t want to make unlimited calls to an API, that can get expensive
- And we may not want to send all of our data to a third-party - in my example I did - but there are plenty of embedding models that you can run yourself!
- And this works differently! So how does it work? It uses something called embeddings, what are those?

Embeddings



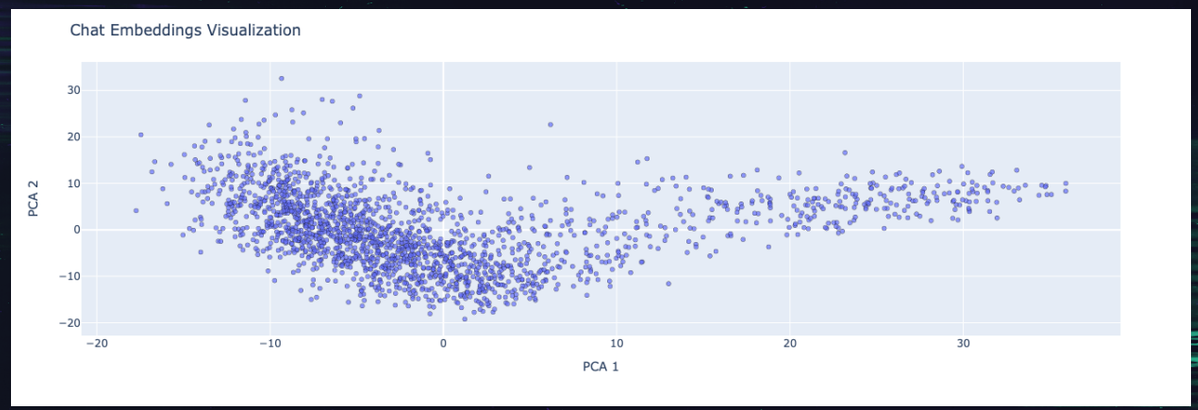


- At its core, 'embedding' refers to the process of converting textual data into numerical vectors that exist in a multi-dimensional space.
- An easy way to think of embeddings is as pins on a map - words or phrases that are similar are pinned closer together while different ones are further apart.
- Essentially, it is a method to quantify and represent the nuanced meanings of words or phrases in a way that captures their semantic relationships.
- Consider three words: apple, orange, and computer
- We instinctively know that both apples and oranges are fruit and that computers are electronic devices. If we were to place these words in a space based on their meanings we would group apple and orange together and place computer further away.
- Spatial arrangement mirrors real-world relationships
- But we are not limited to 2 dimensional space, we can also plot embeddings within three dimensions, or even high dimensional space
- Word2vec, commonly uses vectors with 100 to 300 dimensions and it does it very quickly and efficiently
- In other words, we can take a huge corpus of text and embed it very inexpensively



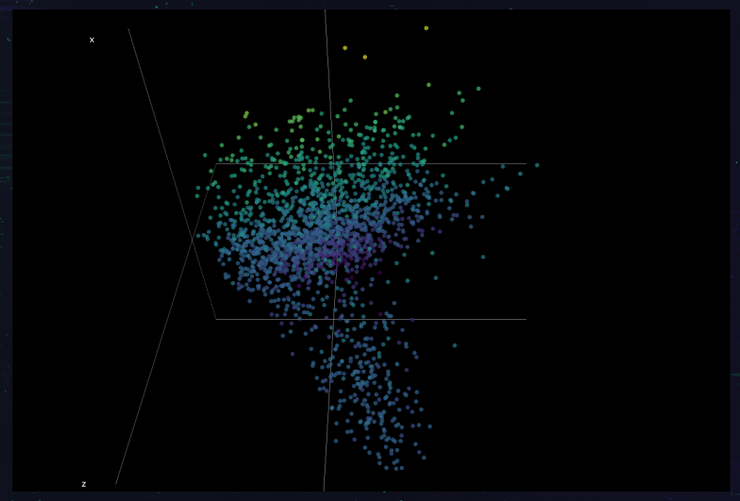
- So we have these two years of ransomware chats, its a lot of data… what should we do with them?

Retrieval Augmented Generation (RAG)

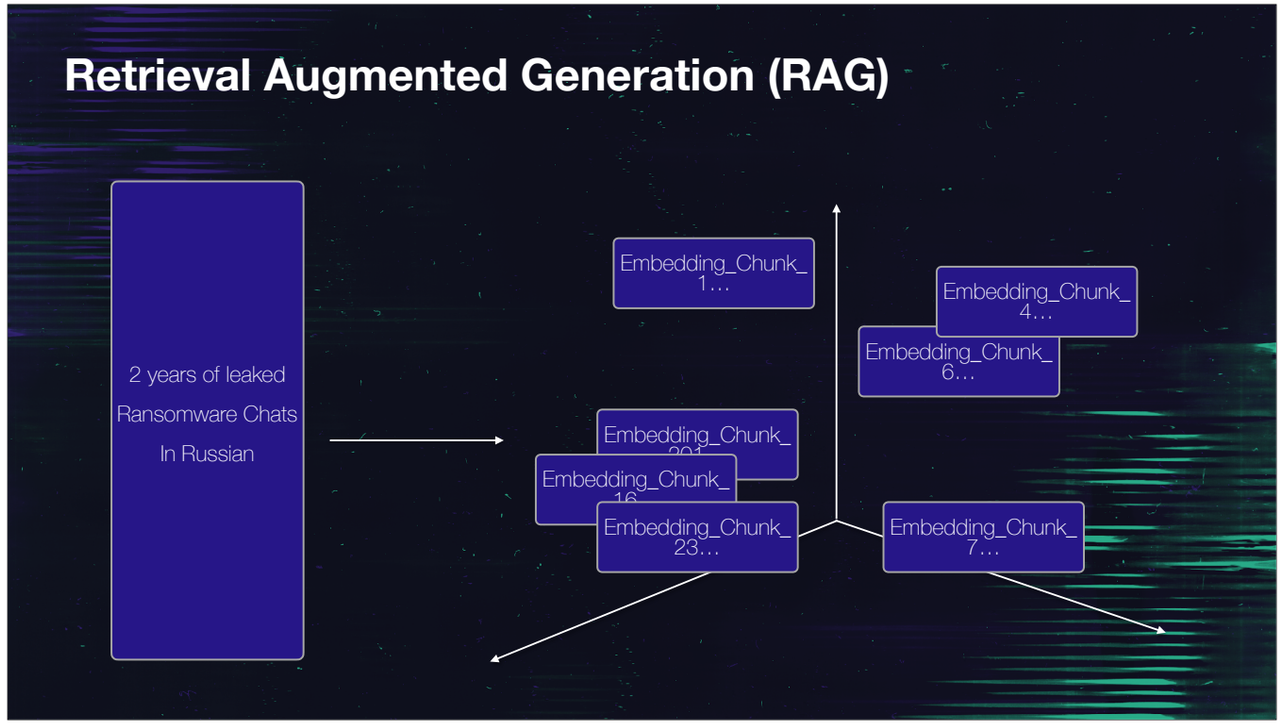


- Well we should embed them!
- No! Not like that
- Go 3D

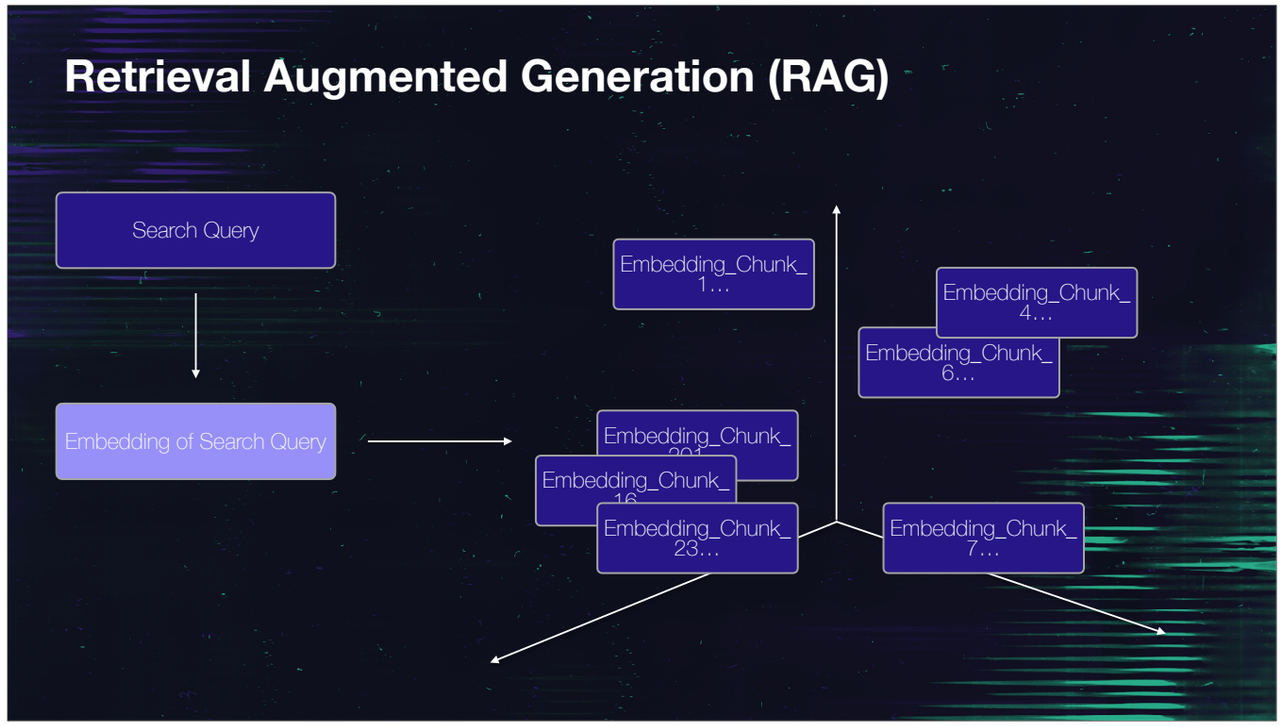
Retrieval Augmented Generation (RAG)



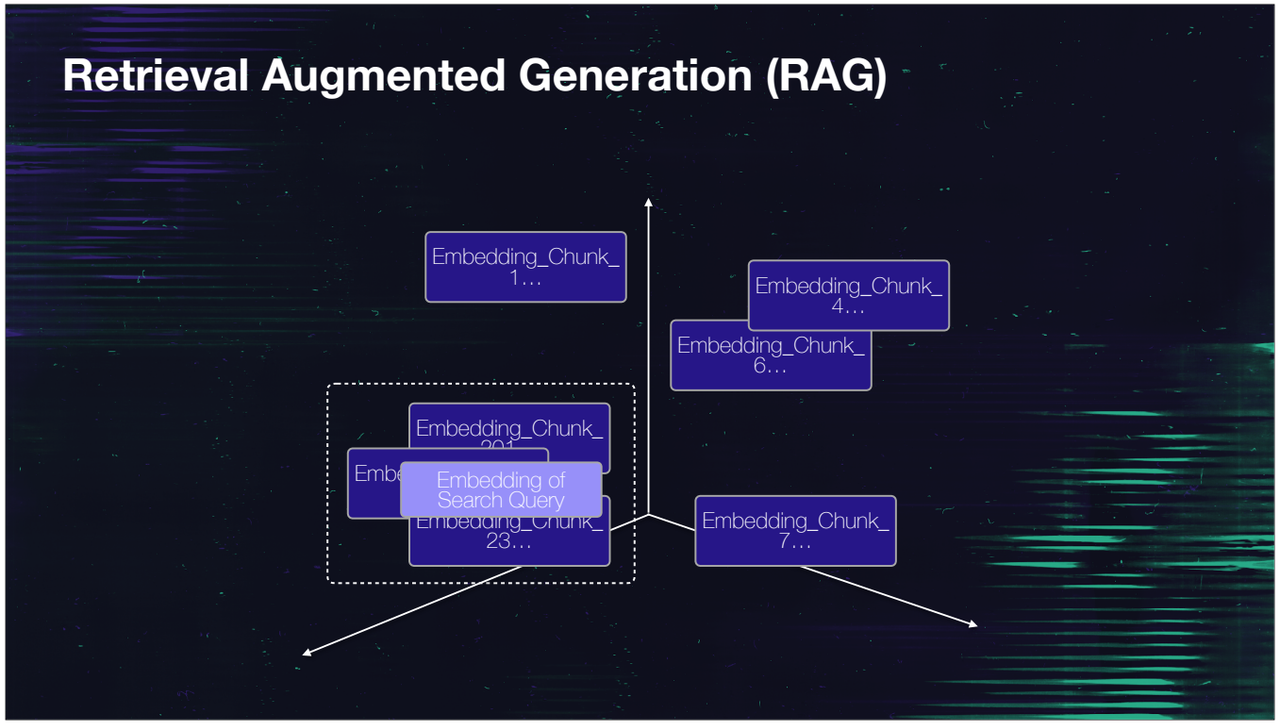
- Ok that’s better
- Now make em rotate
- There we go!
- Ha ha so many dots, this guy definitely knows his stuff.



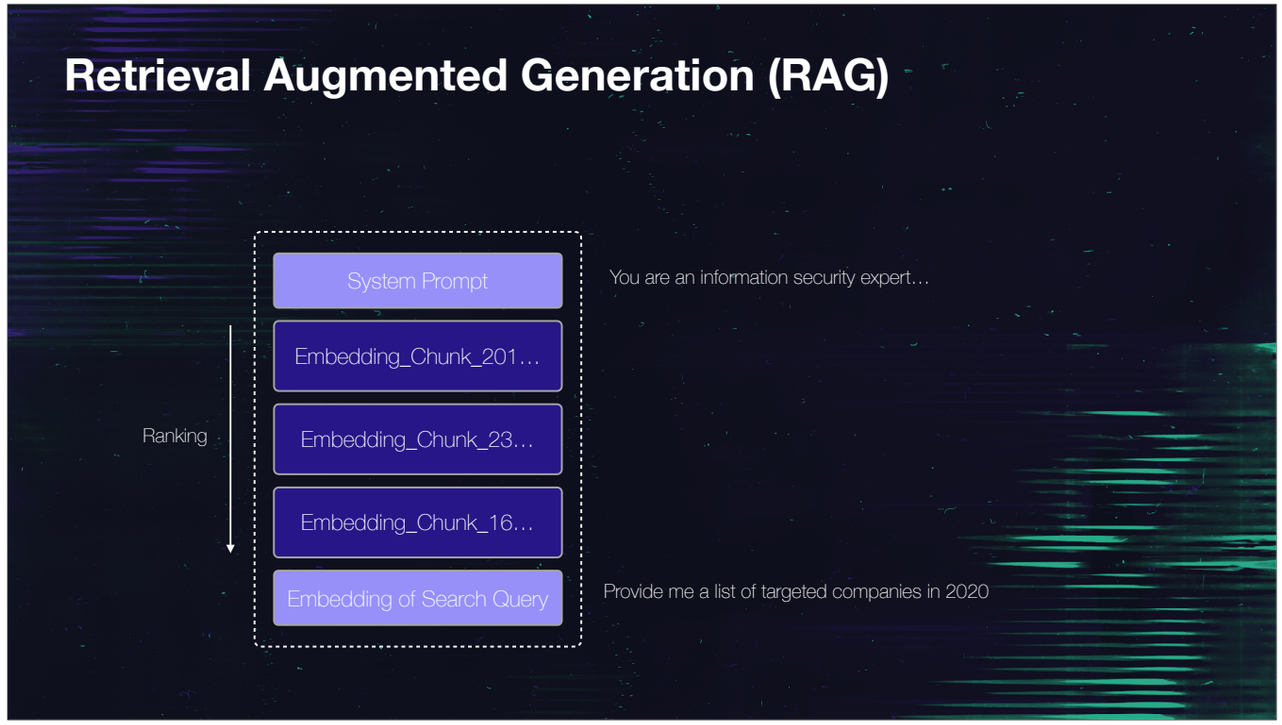
- Ok, so what's going on here?
- Well, we took 2 years of chat logs and we basically loaded it as chunks into this high-dimensional space
- But what does that get us, well we start to see clusters of chunks, that are closer to one another which means they may be related!
- Great! How do we use this?



- Well, the huge value of embeddings is that we can take any arbitrary text and compare it to our own data
- All we need to do is create an embedding of the search query.



- That query will be a point somewhere within the space
- And that means we can evaluate the points that are closest to it
- Those points are tied to real chat data so we can retrieve it



- And once we have retrieved it, we can rank the results, and choose how many of the chats we want to include in a summarization prompt that we send to the model
- So we give the model a role - we may even make this a few shot prompt if the model requires additional context
- We include some chat data, and then we include our original question in this case
- What are the top victims discussed by this ransomware group in 2020?

Retrieval Augmented Generation (RAG)

Enter your query:

Provide me a list of targeted companies in 2020

Top relevant chat chunks:

960 :25] <prof> Web Domain Revenue source ...

1347 3811 target@q3mcco35auwcstmt.onion stern@q3mcc...

875 3mcco35auwcstmt.onion 80+ людей готовы прийти ...

935 .onion bentley@q3mcco35auwcstmt.onion стерн оч...

732 T20:04:07.456951 target@q3mcco35auwcstmt.onion...

Answer based on the most relevant chat chunk:

Here is the list of the companies that seem to be targeted based on the provided chat message:

1. The Money Store Company (themoneystore.com)
2. Broe Group Company (broe.com)
3. Evertz Microsystems Ltd. (evertz.com)
4. Flemington National Bank (flemington.com)
5. Network Capital Funding Corporation (networkcapital.net)
6. Pac-Van Inc. (pacvan.com)
7. The Siegfried Group LLP (siegfriedgroup.com)
8. Advance Tabco (advancetabco.com)
9. Life Quotes Inc. (lifequotes.com)
10. Mellanox Technologies Inc. (mellanox.com)
11. New Castle Building Products (ncbp.com)
12. Watermark Retirement Communities Inc. (watermarkcommunities.com)
13. Northtown Automotive Companies (northtownauto.com)
14. PayneWest Insurance Inc. (paynewest.com)
15. The Verdin Company (verdin.com)
16. Tom Holzer Ford (tomholzerford.com)
17. Tiong Seng Group (tiongseng.com.sg)
18. The Matches Group (matches.com)…

- The script I wrote for this is real basic, it pulls the top five relevant chats and then tries to answer the users question
- And in this case it keyed in on a message within the chat that listed a number of victims in 2020
- Is this all of the victims, no very likely it is not
- But it gives us a very quick way to get answers grounded in actual documentation
- And it allows us to ask important threat intelligence questions in a non-traditional way

Retrieval Augmented Generation (RAG)

Enter your query:

list top antivirus discussed by adversaries along with bypass suggestions from the chats, be specific.

Top relevant chat chunks:

1332 : Microsoft-Windows-Windows Defender/Oper...

572 .onion Microsoft Defender Antivirus has detec...

225 пании позавчера \n[16:39:31] <target> меня ту...

822 м 2020-09-16T19:27:46.492184 bentley@q3mcco35a...

1173 1116\nTask Category: None\nLevel: Warni...

Answer based on the most relevant chat chunk:

The main antivirus discussed in the conversation by the adversaries is "Windows Defender Antivirus." They seem to be discussing bypass techniques, specifically using **Trojan:Win32/Wacatac.B!ml** and **Trojan:Win32/Wacatac.C!ml** to bypass the Windows Defender operating system. They also discuss the detection sources for these Trojans, referring specifically to 'Local Machine,' 'System,' 'Downloads and Attachments,' and 'Internet.'

The adversaries note that they have malware or potentially unwanted software detected on their systems. They discuss file locations and specific Trojans, documenting their severity as severe, their detection types as FastPath and their detection origins.

They also discuss rebooting the system and talk about the use of DLLs, which are potentially unwanted programs or malware that could bypass Windows Defender's security measures as they tend to be less suspect. Moreover, they talk about how the DLL files are less likely to get picked up by security measures.

The final chats suggest they have attempted to use a bot with some troubles, pointing to potential automatized tasks to keep this infection ongoing. A user even refers to the need to 'crypt' files, suggesting a way to tamper with the malware signature so as to be not easily detectable by antiviruses.

- In this case I'm just asking for a summary of antivirus discussion, I didn't ask specifically for windows defender
- But what we got was a discussion related to two specific and real (I checked) trojans that Microsoft has been playing cat and mouse with for awhile now

Retrieval Augmented Generation (RAG)

Enter your query:

what is the most petty thing discussed in the chat logs?

Top relevant chat chunks:

1574 устали от этого человека который ведет перегов...

677 JP2Z\n103.47.174.177 admin 0l0ctyQh243O63uD\n2...

1341 cstmt.onion это я у разработчиков в комментари...

1571 .onion палит 2021-12-06T12:27:58.771746 modnik...

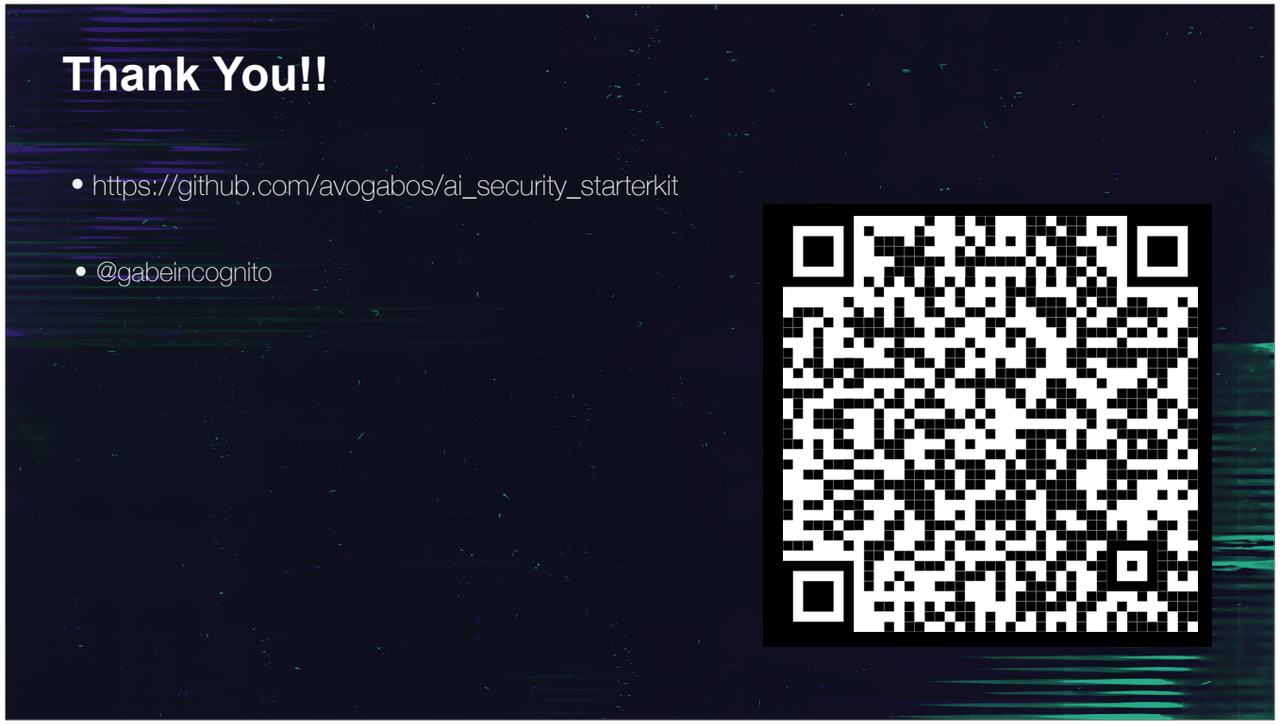
1470 24511 mango@q3mcco35auwcstmt.onion stern@q3mcc...

Answer based on the most relevant chat chunk:

The most petty thing discussed in the chat logs seems to be the manipulative negotiations regarding payments. The individuals in the conversation are deliberating on how to intimidate their partners into increasing the price. The intent seems to be more about power and manipulation than any substantive business negotiation, thus making it seem petty given the ominous undertone of the conversation.

For instance, lines like '**может и поломали, да**', which translates to 'maybe we even broke them, yes' and '**уебали этого паршивого переговрщика**' or 'we fucked up this shitty negotiator' reveal a sense of petty satisfaction derived from out maneuvering their counterparts, not seeming to genuinely consider or respect their negotiation partner's position or interests.

- We can even ask sentiment analysis questions
- In this case, what is the most petty thing discussed in this chat
- Turns out - manipulative negotiations regarding payments. The individuals in the conversation were deliberating on how to intimidate their partners into increasing the price.
- And that's all to say that you can also have fun with this - its a new way of exploring data.
- And my god is this fast - my script is very basic, it could be improved in a multitude of ways, but its there and it is hopefully enough to get you started on this journey.



So I wrote three simple scripts that you can play around with right now

That’s going to be it for me, I want to close by saying that I am around today, I look like this, and I am here to help - I would love to talk to you about this and I would love to see what you are building and to help you incorporate any of these methods we discussed.

The code is live here, take a photo, please let me know how it can be improved

I am at GabeIncognito on Twitter

LABS
CON
LABSCON 2023
SCOTTSDALE AZ